



Department for
Digital, Culture,
Media & Sport

Aligning AWS observability approach with Secure by Design

Contents

Contents	2
Background	3
2. Observability Architecture	4
3. AWS Observability Data Sources	4
4. Logging Architecture	5
5. Detection, response, and SIEM	6
7. Observability for Containers and Serverless Workloads	7
More information	7

Background

AWS observability helps organisations monitor the health, performance and reliability of services running on Amazon Web Services (AWS).

As government organisations expand their use of cloud services across multiple AWS accounts, regions and availability zones, it becomes more difficult to maintain consistent monitoring, logging and alerting. Relying on separate tools and manual processes can lead to:

- inconsistent visibility across systems and services
- slower detection and resolution of incidents
- increased effort to investigate and correlate logs, metrics and traces

These challenges reduce operational resilience and increase security and service delivery risks, particularly in large and distributed cloud environments.

Secure by Design

[Secure by Design](#) is a government framework that integrates cyber security into the design and delivery of digital services from the start. It aims to ensure security is built into systems and services throughout their lifecycle, rather than being added later.

This guidance explains how government organisations can align their AWS observability architecture with [Secure by Design principles](#).

AWS provides several native services that can help organisations build and operate an effective observability capability, including:

- [Amazon CloudWatch](#)
- [AWS X-Ray](#)
- [Amazon Managed Prometheus](#)
- [Amazon Managed Grafana](#)
- [AWS CloudTrail](#)
- [AWS Config](#)
- [Amazon EventBridge](#)

Secure by Design on security.gov.uk

- [Secure by Design policy](#)
- [Implementing Secure by Design](#)
- [Guide to adopting Secure by Design](#)

2. Observability Architecture

Security monitoring and ownership

The observability architecture should [collect security telemetry consistently across AWS accounts, Regions, workloads and services](#). This should give security teams reliable information about:

- [identities and access](#)
- infrastructure changes
- network activity
- application behaviour
- security events

For more information, see the guidance on identity and access management.

Use a centralised observability model based on a structured [AWS account](#) design. A dedicated security account should host security monitoring, threat detection, security analytics and response automation. A separate logging account should store security telemetry and keep it separate from operational workloads.

This supports the Secure by Design principle [Create responsibility for cyber security risk](#) by establishing clear ownership of security monitoring, telemetry and incident response.

Government organisations should define these responsibilities in their operating model:

- security teams are responsible for central security capabilities, governance and oversight
- platform and application teams are responsible for securing the workloads they operate

This aligns with a DevSecOps approach, where security is built into the software delivery lifecycle rather than added later.

Design usable security controls

[Observability controls](#) should help teams detect, investigate and respond to security issues. They should not add unnecessary complexity.

You should design monitoring tools around the needs of the people who use them. This includes access controls, alerts, dashboards and investigation workflows.

To support effective security operations:

- provide enough context to investigate alerts quickly
- prioritise alerts based on risk to reduce alert fatigue
- use dashboards to show the security posture of workloads and services

- follow the principle of least privilege while allowing authorised users to carry out monitoring and response activities

This supports the Secure by Design principle [Design usable security controls](#) by making security controls easier to use and operate as part of normal business activities.

Defend in depth

Do not rely on a single monitoring capability. An effective observability architecture should provide multiple layers of security visibility.

These layers can include:

- identity monitoring
- configuration assessment
- network monitoring
- threat detection
- vulnerability management
- security analytics

Together, these capabilities provide broader coverage and help identify gaps in individual controls.

This supports the Secure by Design principle [Defend in depth](#) by reducing the risk that a single control failure will go undetected.

3. AWS Observability Data Sources

Collect security telemetry

Your observability architecture should collect telemetry from multiple sources to provide visibility across identities, infrastructure, applications, networks and security services.

Identity and access

Identity and access telemetry is a critical source of security information.

[AWS CloudTrail](#) can capture API activity, administrative actions, resource changes and service interactions across AWS environments.

You should monitor activity from [AWS Identity and Access Management](#) (IAM), [AWS IAM Identity Center](#) and [AWS Security Token Service](#) (STS) to identify:

- unusual sign-in activity
- attempts to gain additional privileges
- misuse of privileged accounts
- unexpected changes in access patterns

Networks

Network telemetry helps organisations understand how workloads communicate with each other and with external systems.

Useful sources of network telemetry include:

- VPC Flow Logs
- Transit Gateway Flow Logs
- load balancer access logs
- DNS query logs
- network security service logs

These sources can help identify:

- suspicious network activity
- unauthorised access attempts
- lateral movement between systems
- potential data exfiltration

Infrastructure configuration

You should monitor infrastructure configuration to understand how AWS resources change over time.

[AWS Config](#) can:

- record configuration history
- assess compliance with security requirements
- identify configuration drift

Threat detection

You should use AWS security services to generate threat detection telemetry.

Services such as [Amazon GuardDuty](#), [Amazon Inspector](#) and [AWS Security Hub](#) can help identify:

- suspicious activity
- vulnerabilities
- security weaknesses

Secure by Design alignment

Collecting and analysing identity, network, configuration and threat detection telemetry supports the Secure by Design principle [Build in detect and respond security](#). It helps organisations detect security issues as part of normal operations rather than relying on manual investigation.

Continuous monitoring also supports the principle [Embed continuous assurance](#). Regular analysis of observability data helps organisations:

- assess their security posture
- identify weaknesses in security controls
- verify that controls remain effective as environments change

4. Logging Architecture

You should use a centralised logging architecture as part of your AWS observability approach.

Collect security logs from relevant AWS accounts, Regions, applications and infrastructure components. This helps create a complete record of security-related activity across your environment.

For more information, see the [NCSC guidance on logging and monitoring](#).

Protect log data

Store logs in a dedicated, secure repository.

Logs should:

- be encrypted using customer-managed [AWS Key Management Service](#) (KMS) keys
- be protected from unauthorised deletion or modification
- be retained in line with organisational and legal requirements

Access to log data should be controlled using:

- strong authentication
- role-based access controls
- segregation of duties

Secure by Design alignment

Centralised logging supports the Secure by Design principle [Embed continuous assurance](#) by ensuring security and operational events are continuously recorded and available for analysis.

Reliable logging helps organisations:

- investigate security incidents
- monitor the effectiveness of security controls
- demonstrate compliance with security requirements

- verify that controls remain effective as services and environments change

5. Detection, response, and SIEMs

Detection and response

Observability data should feed into security monitoring and analysis tools, including Security Information and Event Management (SIEM) platforms.

A SIEM helps security teams analyse and correlate AWS security data with information from other environments, such as:

- endpoints
- networks
- applications
- other cloud platforms

This provides a broader view of security activity across the organisation.

AWS native security services should be used where appropriate to support:

- security monitoring
- security finding aggregation
- automated response activities

Security findings should be managed centrally and integrated with existing security operations processes. This helps security teams prioritise and respond to risks consistently.

Investigation and response

Security events should trigger appropriate response activities, including:

- creating incidents
- notifying responders
- enriching security data with additional context
- initiating investigations
- carrying out approved response actions

This supports the Secure by Design principle [Build in detect and respond security](#) by embedding detection and response capabilities into the AWS environment from the start.

Security telemetry should flow directly into operational security processes so that events can be analysed, prioritised and acted on quickly.

Design flexible architectures

Your observability architecture should support integration with different SIEM platforms, security tools and operating models.

Avoid creating unnecessary dependency on a single monitoring solution. Design the architecture so that organisations can adopt new security capabilities and technologies as their requirements change.

This supports the Secure by Design principle [Design flexible architectures](#).

Automated response

You should assess security findings based on:

- business impact
- threat severity
- organisational risk appetite

Use automation where it can improve the speed and consistency of incident response.

Examples of automated actions include:

- creating security incidents
- disabling suspicious credentials
- isolating compromised resources
- initiating additional investigation activities

Design and govern automated responses carefully to reduce the risk of disrupting business services.

Embed continuous assurance

You should regularly review:

- detection coverage
- alert quality
- response effectiveness
- incident outcomes

This supports the Secure by Design principle [Embed continuous assurance](#) by helping organisations identify improvements and maintain effective security operations over time.

6. Observability for Containers and Serverless Workloads

The observability architecture should provide the same level of security visibility for container and serverless workloads as it does for traditional infrastructure.

For container platforms, including [Amazon Elastic Kubernetes Service \(EKS\)](#), collect telemetry that helps you monitor:

- Kubernetes audit activity
- container runtime behaviour
- container image security
- workload and configuration changes
- deployment activity

This can help identify:

- unauthorised deployments
- excessive permissions
- vulnerable components
- suspicious runtime activity

For serverless workloads, you should monitor:

- [AWS Lambda](#) execution logs
- API Gateway activity
- function permissions
- invocation and event patterns

This can help identify:

- excessive permissions
- unexpected execution behaviour
- application-level attacks

- unusual usage patterns

You should ensure that new container and serverless workloads inherit appropriate monitoring and security controls by default, rather than relying on individual teams to implement them separately.

You can do this by:

- building monitoring into platform standards
- including observability requirements in platform standards and reference architectures

Secure by Design alignment

Observability supports the Secure by Design principle [Minimise the attack surface](#) by helping teams identify:

- unnecessary permissions
- exposed services
- vulnerable components
- insecure configurations

Security monitoring should help organisations identify and reduce unnecessary exposure before it can be exploited.

More information

- [Secure by Design principles \(UK Government Security\)](#)
- [Secure by Design activities \(UK Government Security\)](#)
- [Introduction to logging for security purposes \(NCSC\)](#)
- [Logging and monitoring \(NCSC\)](#)
- [Cloud security guidance \(NCSC\)](#)
- [Managing observability \(UK Government Security\)](#)